

Incident Response Policy

Nimbus Analytics Inc. -- Security Department

Effective Date: October 1, 2025

1. Purpose

This policy establishes the process for detecting, responding to, and recovering from security incidents affecting Nimbus Analytics systems or data, and defines notification obligations consistent with our SOC 2 and GDPR commitments.

2. Incident Severity Levels

SEV-1 (Critical): confirmed data breach involving Tier 1 data, or full production outage. SEV-2 (High): suspected breach, partial outage, or active exploitation attempt. SEV-3 (Medium): policy violation without confirmed data exposure. SEV-4 (Low): minor anomaly requiring investigation but no immediate risk.

3. Detection and Reporting

Employees who suspect a security incident must report it immediately via security-incidents@nimbusanalytics.example or the #security-incident Slack channel, which pages the on-call security engineer. Do not attempt to investigate or remediate a suspected breach independently, as this can destroy forensic evidence.

4. Response Process

Upon a SEV-1 or SEV-2 declaration, the on-call security engineer assembles an incident response team within 15 minutes, including Engineering, Legal, and Communications as needed. The team follows a standard process: contain, eradicate, recover, and conduct a post-incident review within 5 business days of resolution.

5. Regulatory Notification

For confirmed breaches involving EU personal data, Legal must notify the relevant supervisory authority within 72 hours, per the GDPR Compliance Overview. For breaches affecting US customers, notification timelines follow applicable state breach notification laws, coordinated by Legal.

6. Communication

All external communication regarding a security incident, including customer notifications, must be approved by Legal and the VP of Communications before release. Employees must not discuss active incidents publicly or on social media.

7. Post-Incident Review

Every SEV-1 and SEV-2 incident receives a blameless post-incident review documenting root cause, timeline, and corrective actions, tracked to completion in the engineering issue tracker. Findings that indicate a control gap feed back into this policy and the Access Control Policy.

8. Testing

The incident response process is tested via tabletop exercises at least twice per year, coordinated with the disaster recovery game-days described in the System Architecture Overview.